

BILGI GÜVENLİĞİ VE ETİK

TRABZON ÜNİVERSİTESİ / UYGULAMALI BİLİMLER YÜKSEKOKULU / YÖNETİM BİLİŞİM SİSTEMLERİ



KONULAR

1. Bilgi Güvenliđi ve Etik Kavramları
2. CIA Üçgeni (Gizlilik, Bütünlük, Erişilebilirlik)
3. Etik ve Hukuki Temeller
4. Bilişim Suçları ve Türk Ceza Kanunu (TCK)
5. Kişisel Verilerin Korunması Kanunu (KVKK)
6. Bilgi Güvenliđi Standardı (ISO/IEC 27001)
7. Risk Yönetimi ve Değerlendirme Süreci

BİLGİ GÜVENLİĞİ VE ETİK NEDİR?

Bilgi güvenliği, bilginin yetkisiz erişim, kullanım, değiştirme, ifşa, tahrip veya bozulmasını önlemek amacıyla alınan teknik, idari ve yasal önlemlerin toplamıdır.

Etik, ahlak felsefesi olarak da bilinen; doğru ile yanlışın, iyi ile kötünün, adil ile adaletsizin ne olduğunu inceleyen felsefe dalıdır. İnsanların toplum içindeki davranışlarını, kararlarını ve bu kararların arkasındaki ilkeleri sorgular.

Bilişim ve bilgi güvenliği bağlamında etik; teknolojiyi ve veriyi kullanırken başkalarının haklarına saygı duymak, gizliliği korumak, dürüstlükten ödün vermemek ve yazılımların ya da sistemlerin zarar verme potansiyeline karşı ahlaki bir sorumluluk üstlenmek anlamına gelir.

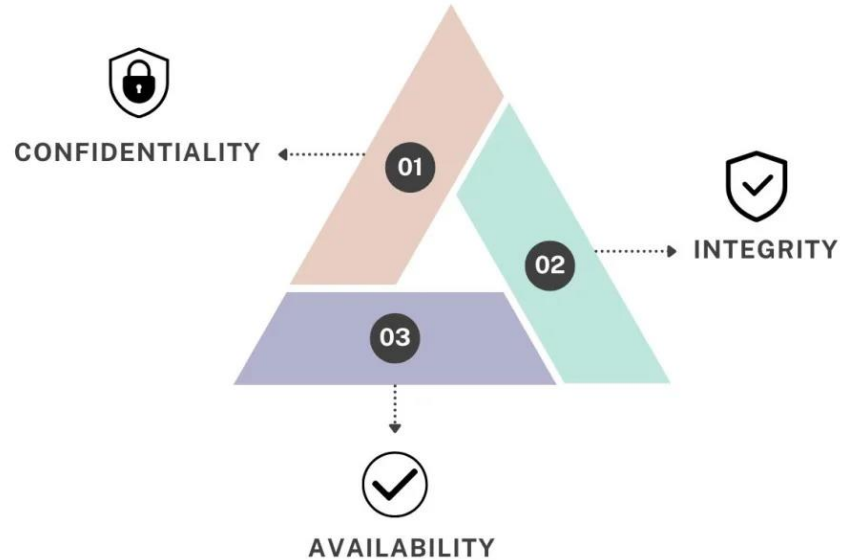
CIA ÜÇGENİ NEDİR?

Bilgi güvenliğinin temel yapı taşı, **CIA Üçgeni** adı verilen üç temel bileşenden oluşur:

- ☐ **Gizlilik (Confidentiality):** Bilginin yalnızca yetkili kişiler veya sistemler tarafından erişilebilir olmasını sağlamak.
- ☐ **Bütünlük (Integrity):** Bilginin yetkisiz kişiler tarafından değiştirilmediğini, bozulmadığını ve doğruluğunun korunduğunu garanti etmek.
- ☐ **Erişilebilirlik (Availability):** Bilginin ve ilgili sistemlerin ihtiyaç duyulduğunda yetkili kullanıcılar tarafından kullanılabilir durumda olması.

CIA ÜÇGENİ NEDİR?

CIA Triad



GİZLİLİK (CONFIDENTIALITY)

Gizlilik (Confidentiality), hassas veya özel bilgilerin yalnızca bunlara erişmeye yetkisi olan kişiler, sistemler veya süreçler tarafından okunabilmesini ve görülebilmesini sağlayan temel bir güvenlik ilkesidir.

Diyelim ki mobil bankacılık uygulamanıza giriş yapacaksınız. TC kimlik numaranızı ve şifrenizi girdiniz. Bankanın sistemi arka planda şunu kontrol eder: *"Bu verileri görmeye ve bu hesabı yönetmeye gerçekten yetkisi olan kişi bu mu?"* Eğer doğru şifreyi girerseniz sistem size hesap özetinizi gösterir (Gizlilik sağlanmıştır). Ancak şifrenizi bilmeyen bir başkası telefonunuzu eline alsa bile uygulamaya giremez ve hesap detaylarınızı göremez. Burada şifre, gizliliği koruyan bir bariyerdir.

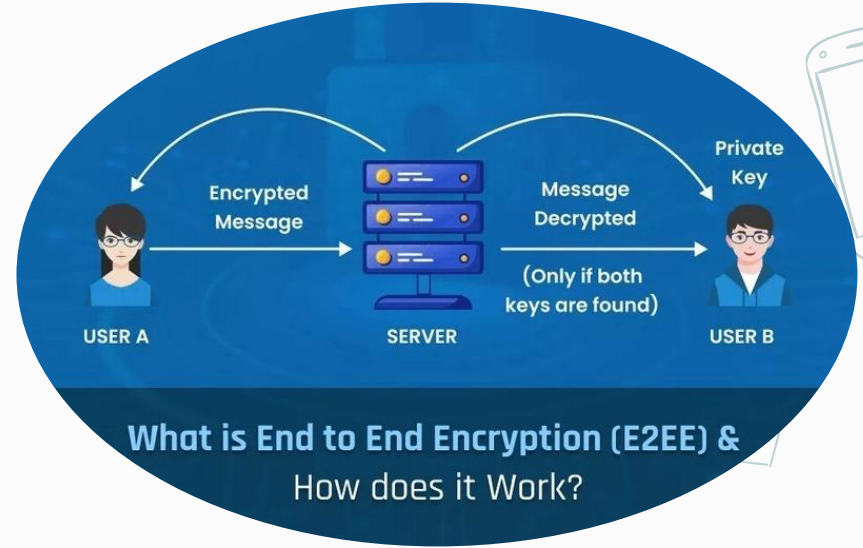
GİZLİLİK (CONFIDENTIALITY)

Bilişim Dünyasından Örnek: Şifrelenmiş E-posta (End-to-End Encryption)

İki kişi arasında gönderilen gizli bir mesajı düşünelim. Mesaj internet üzerinden seyahat ederken aradaki servis sağlayıcılar, hackerlar veya internet ağını dinleyen kötü niyetli kişiler bu veriyi ele geçirebilir.

Eğer mesaj şifrelenmemiş (plain text) ise okudukları anda gizlilik ihlal edilmiş olur.

Ancak uçtan uca şifreleme (End-to-End Encryption) kullanılıyorsa, mesaj sadece gönderenin ve alıcının cihazındaki anahtarla çözülebilir. Aradaki herkes mesajı görse bile sadece anlamsız karakterler



GİZLİLİK (CONFIDENTIALITY)

Bilişim Dünyasından Örnek: Şifrelenmiş E-posta (End-to-End Encryption)

İki kişi arasında gönderilen gizli bir mesajı düşünelim. Mesaj internet üzerinden seyahat ederken (örneğin bir mesajlaşma uygulamasında) aradaki servis sağlayıcılar, hackerlar veya internet ağını dinleyen kötü niyetli kişiler bu veriyi ele geçirebilir.

Eğer mesaj şifrelenmemiş (plain text) ise okudukları anda gizlilik ihlal edilmiş olur.

Ancak uçtan uca şifreleme (End-to-End Encryption) kullanılıyorsa, mesaj sadece gönderenin ve alıcının cihazındaki anahtarla çözülebilir. Aradaki herkes mesajı görse bile sadece anlamsız karakterler

BÜTÜNLÜK (INTEGRITY)

Bütünlük (Integrity), verinin veya bilginin yetkisiz kişiler tarafından değiştirilmesini, bozulmasını ya da tahrif edilmesini önleyerek **doğruluğunu ve güvenilirliğini** korumayı amaçlayan temel bir güvenlik ilkesidir.

Bütünlük sağlandığında, bilginin kaynağında çıktığı andan hedef ulaştığı ana kadar hiçbir müdahaleye uğramadığı garanti edilir.

BÜTÜNLÜK (INTEGRITY)

Diyelim ki bir arkadaşınıza internet bankacılığı üzerinden **100 TL** gönderdiniz.

Eğer sistemde veri bütünlüğü korunmuyorsa, kötü niyetli bir kişi bu veri transferine araya girip müdahale edebilir ve tutarı **10.000 TL** olarak değiştirebilir.

Karşı tarafa giden tutarın değişmesi veya işlem kaydının bozulması, bütünlük ilkesinin ihlal edildiğini gösterir.

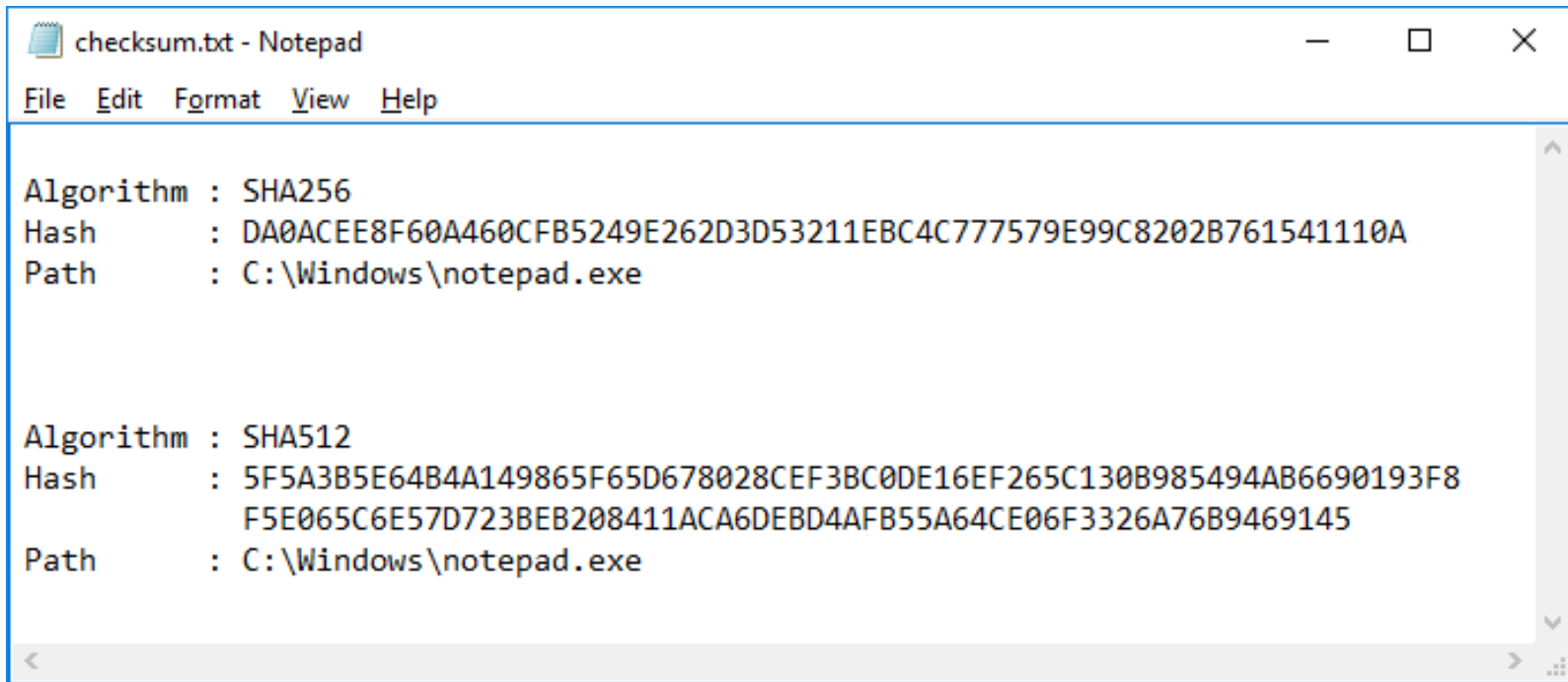
BÜTÜNLÜK (INTEGRITY)

İnternetten resmi bir kaynaktan açık kaynaklı bir yazılım indirdiğinizi düşünün. Yazılımı sunan site, dosyanın **SHA-256** gibi matematiksel bir **hash değeri**ni (parmak izini) de paylaşır.

Siz dosyayı indirip kendi bilgisayarınızda bir hash hesaplaması yaptığınızda çıkan sonuç, resmi sitedekiyle birebir uyuyorsa dosyanın bütünlüğü korunmuştur.

Eğer araya bir hacker girip yazılımın içine virüs enjekte ettiyse, dosyanın içeriği değişeceği için hash değeri de tamamen farklı çıkacaktır; bu da bütünlüğün bozulduğunu ele verir.

BÜTÜNLÜK (INTEGRITY)



```
checksum.txt - Notepad
File Edit Format View Help

Algorithm : SHA256
Hash      : DA0ACEE8F60A460CFB5249E262D3D53211EBC4C777579E99C8202B761541110A
Path      : C:\Windows\notepad.exe

Algorithm : SHA512
Hash      : 5F5A3B5E64B4A149865F65D678028CEF3BC0DE16EF265C130B985494AB6690193F8
           F5E065C6E57D723BEB208411ACA6DEBD4AFB55A64CE06F3326A76B9469145
Path      : C:\Windows\notepad.exe
```

BÜTÜNLÜK (INTEGRITY)

Windows 11 **Başlat** menüsüne sağ tıklayın ve **Terminal** veya **PowerShell**'i açın. Şu komutu yazın ve Dosya_Yolu kısmını kontrol etmek istediğiniz dosyanın gerçek yoluyla değiştirin:

```
Get-FileHash -Path "C:\dosya\yolu\dosyaadi.iso" -Algorithm SHA256
```

(Algoritma olarak SHA256 yerine MD5 veya SHA1 de yazabilirsiniz).

BÜTÜNLÜK (INTEGRITY)

macOS'ta Hash Kontrolü

macOS üzerinde en yaygın kullanılan algoritma **SHA-256**'dır. **Terminal** uygulamasını açarak şu komutları kullanabilirsiniz:

SHA-256 için:

```
shasum -a 256 /dosya/yolu/dosyaadi.iso
```

MD5 için:

```
md5 /dosya/yolu/dosyaadi.iso
```

BÜTÜNLÜK (INTEGRITY)

Linux'ta Hash Kontrolü

Linux dağıtımlarında (Ubuntu, Fedora, Mint vb.) her algoritmanın kendi özel komut aracı vardır. Terminali açıp şu komutları çalıştırabilirsiniz:

SHA-256 için:

```
sha256sum /dosya/yolu/dosyaadi.iso
```

MD5 için:

```
md5sum /dosya/yolu/dosyaadi.iso
```

SHA-1 için:

```
sha1sum /dosya/yolu/dosyaadi.iso
```

 **Pratik İpucu:** Dosya yolunu tek tek yazmak yerine, Terminale komutu (örneğin sha256sum) yazıp bir boşluk bıraktıktan sonra dosyayı sürükleyip terminal penceresinin içine bırakabilirsiniz. Dosya yolu otomatik olarak eklenecektir.

ERİŞİLEBİLİRLİK (AVAILABILITY)

Erişilebilirlik (Availability), bilgiye, sistemlere veya hizmetlere **ihtiyaç duyulduğu anda** yetkili kullanıcılar tarafından sorunsuz bir şekilde ulaşıla bilmesini ve kullanılabilmesini sağlayan temel güvenlik ilkesidir.

Gizlilik ve bütünlük sağlansa bile, sistem çalışmıyorsa o bilginin bir anlamı kalmaz.

ERİŞİLEBİLİRLİK (AVAILABILITY)

ATM'ye gittiniz. Ancak ATM ekranında "Sistem Bakımda" yazıyor veya cihaz tamamen kapanmış durumda. Burada paranız güvendedir (gizlilik tamam) ve hesabınızdaki tutar doğrudur (bütünlük tamam), ancak sisteme **erişemediğiniz** için erişilebilirlik ilkesi aksamıştır.

ERİŞİLEBİLİRLİK (AVAILABILITY)

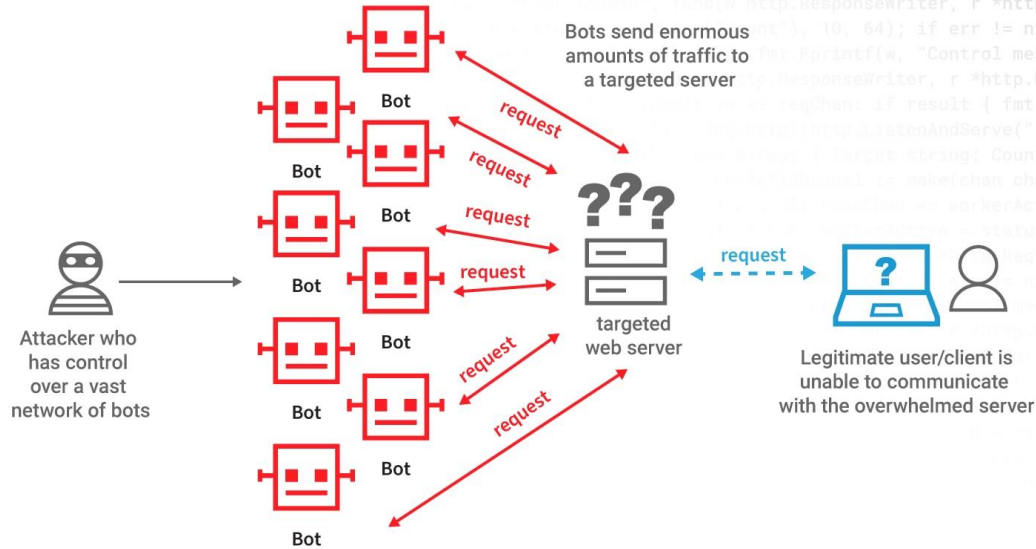
DDoS (Dağıtık Hizmet Engelleme) Saldırıları

Çok popüler bir e-ticaret sitesinin indirim gününde olduğunu düşünün.

Kötü niyetli kişiler, botnet ağlarını kullanarak saniyede milyonlarca sahte istek gönderirler. Sunucu bu yoğun trafik karşısında yanıt veremez hale gelir, çöker veya kitlenir.

Gerçek müşteriler alışveriş yapmak için siteye girmek istediğinde "Sayfaya ulaşamıyor" hatası alır.

DDOS SALDIRISI

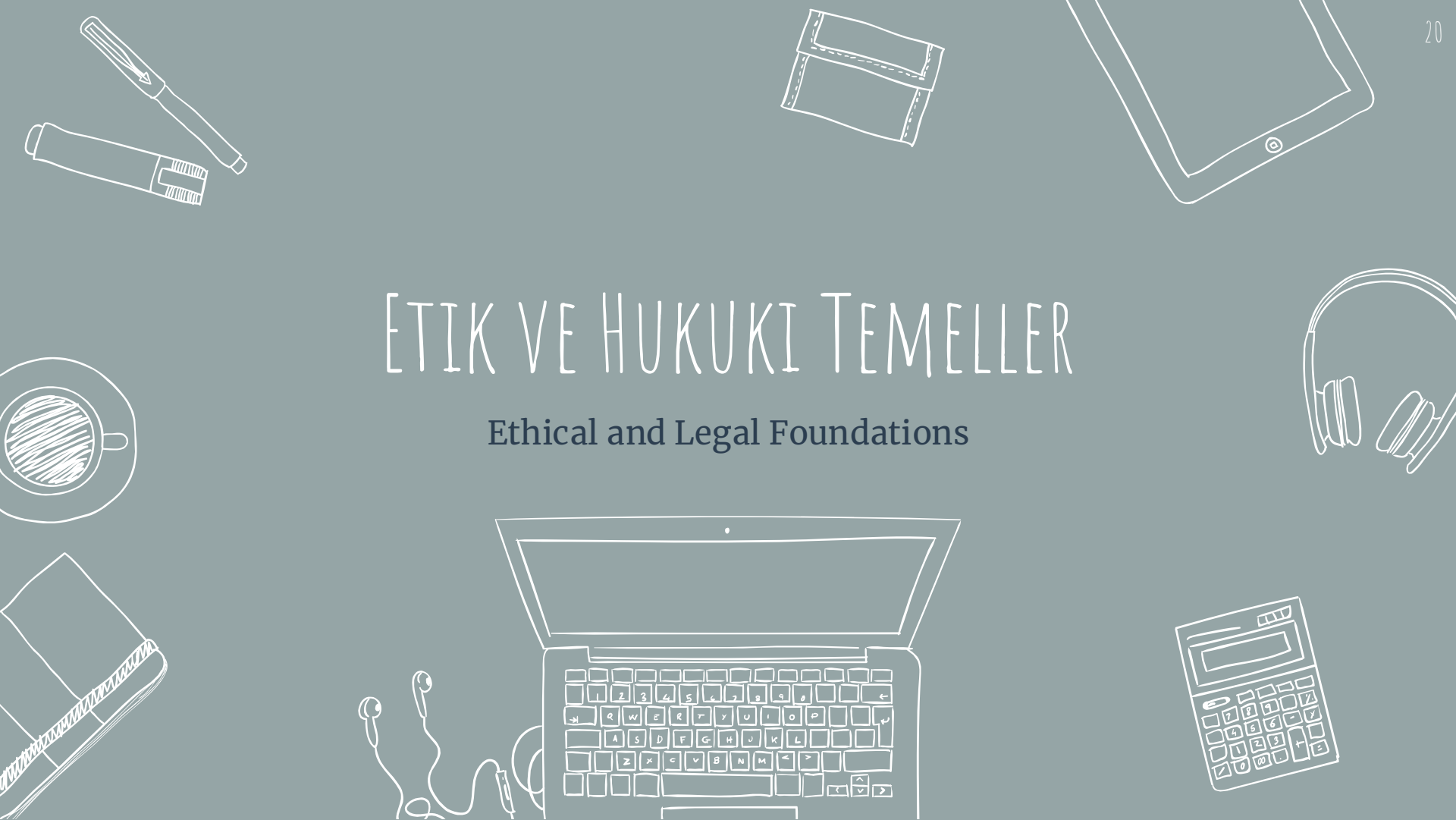


What is volumetric attack?



ETİK VE HUKUKİ TEMELLER

Ethical and Legal Foundations



ETİK VE HUKUKİ TEMELLER

Bilgi güvenliği yalnızca teknik araçlar (firewall'lar, şifreleme algoritmaları, antivirüsler) kullanarak sağlanamaz.

Teknolojiyi kullanan, geliştiren veya yöneten insanların davranış biçimleri, değer yargıları ve bu eylemlerin yasal karşılıkları da güvenliğin en kritik ayağını oluşturur.

ETİK NEDİR VE BİLİŞİMDE NEDEN ÖNEMLİDİR?

Daha önce etiğin genel tanımını yapmıştık; doğru ile yanlışın, iyi ile kötünün felsefi incelemesiydi.

Bilişim etiği ise bilgisayar teknolojilerinin, verilerin ve internetin kullanımı sırasında ortaya çıkan ahlaki ikilemleri ve sorumlulukları ele alır.

ETİK NEDİR VE BİLİŞİMDE NEDEN ÖNEMLİDİR?

Yasal Olmayan vs. Etik Olmayan: Bir davranış hukuka uygun (yasal) olabilir, ancak bu durum onun etik olduğu anlamına gelmeyebilir.

Örneğin, bir şirketin yasal olarak topladığı kullanıcı verilerini gizlice üçüncü taraflara satması (kullanıcı sözleşmesinin küçük yazılarında belirtilmiş olsa bile) yasal bir açık bulabilir ama **etik değildir**.

ETİK NEDİR VE BİLİŞİMDE NEDEN ÖNEMLİDİR?

Yetki Sınırları: Bir sistemde bir açık (bug) bulmuş olmak, o sisteme izinsiz girmek veya verileri kurcalamak için bir hak tanımaz.

Etik hackerlık kuralları tam olarak bu noktada devreye girer.

TEMEL ETİK TEORİLER VE BİLİŞİM YAKLAŞIMLARI

Karar verirken veya teknolojik bir sistem tasarlarken hangi etik çerçevelerin kullanıldığı bilişim etiğinde sıklıkla tartışılır:

- ☐ **Faydacılık (Utilitarianism):** Bir eylemin doğruluğu, en fazla sayıda insana sağladığı toplam fayda ile ölçülür. (Örn: Toplum güvenliğini artırmak için bazı veri izleme sistemlerinin kurulması).
- ☐ **Ödev Etiği (Deontology / Kantçı Etik):** Sonuç ne olursa olsun, uyulması gereken evrensel kurallar ve görevler vardır. (Örn: Veri mahremiyeti bir insan hakkıdır; hiçbir şart altında ihlal edilemez).
- ☐ **Haklar Teorisi (Rights Theory):** Bireylerin temel haklarının (özgürlük, gizlilik, mülkiyet) korunması esastır.

BİLİŞİM SUÇLARI VE HUKUKİ TEMELLER

Etik sınırların ihlal edildiği ve suç teşkil eden durumlar **bilişim suçları (cybercrime)** olarak adlandırılır.

Hukuk sistemleri bu suçlarla mücadele etmek için çeşitli yasalar ve uluslararası düzenlemeler geliştirmiştir.

BİLİŞİM SUÇLARI VE HUKUKİ TEMELLER

- ☐ **Sistemlere Yetkisiz Erişim:** Bir başkasının sunucusuna, e-posta hesabına veya veritabanına izinsiz girmek.
- ☐ **Veri Hırsızlığı ve Tahribatı:** Kişisel veya kurumsal verilerin çalınması, silinmesi veya şifrelenerek istenmesi (Ransomware).
- ☐ **Fikri Mülkiyet İhlalleri:** Yazılım korsanlığı, telif haklarıyla korunan dijital içeriklerin izinsiz kopyalanması veya dağıtılması.

TÜRKİYE'DE BİLİŞİM HUKUKU



TÜRKİYE'DE BİLİŞİM HUKUKU

Türkiye'de bilişim suçları ve bu suçların cezai yaptırımları temel olarak **5237 sayılı Türk Ceza Kanunu (TCK)** içerisinde, "**Bilişim Alanında Suçlar**" başlığı altında düzenlenmiştir. Bu düzenlemeler TCK'nın **243. maddesinden 246. maddesine** kadar olan kısmı kapsar.

BİR BİLİŞİM SİSTEMİNE GİRME VE ORADA KALMA (HACKING)

TCK Madde 243:

Suçun Konusu: Bir bilişim sisteminin bütününe veya bir kısmına, hukuka aykırı olarak girmek veya orada kalmaya devam etmek.

Yaptırım: Bu fiili işleyen kişilere **bir yıla kadar hapis** veya adli para cezası verilir.

Nitelikli Hal (Ceza Artırımı): Eğer bu sistemin verileri yok edilir veya değiştirilirse, ceza **altı aydan iki yıla kadar hapis** cezasına artırılır.

Bankalar, kamu kurumları veya kritik altyapılara yönelik ihlallerde cezalar daha da ağırlaşır.

SİSTEMİ ENGELLEME, BOZMA, VERİLERİ YOK ETME VEYA DEĞİŞTİRME (DDOS, MALWARE VB.)

TCK Madde 244:

Suçun Konusu: Bir bilişim sisteminin çalışmasını engellemek veya bozulmasını sağlamak (örneğin DDoS saldırıları), sistemdeki verileri bozkak, yok etmek, değiştirmek, başka bir yere göndermek veya sisteme başka veriler yerleştirmek (örneğin fidye yazılımı veya virüs bulaştırmak).

Yaptırımı: Bu suçu işleyen kişiler **bir yıldan beş yıla kadar hapis** cezası ile cezalandırılır.

Nitelikli Hal: Eğer bu fiil banka veya kredi kurumlarına ya da kamu kurumlarına ait bir sistem üzerinde işlenirse, verilecek ceza **yarı oranında artırılır**.

BANKA VEYA KREDİ KARTLARININ KÖTÜYE KULLANILMASI (PHISHING, KART KOPYALAMA)

TCK Madde 245:

Suçun Konusu: Başkasına ait bir banka veya kredi kartını elinde bulundurarak ya da sahte kart üreterek kendisine veya başkasına menfaat sağlamak, internet üzerinden başkasının kart bilgileriyle alışveriş yapmak (örneğin oltalama / phishing saldırıları yoluyla).

Yaptırım: Bu suçu işleyenler üç yıldan yedi yıla kadar hapis ve adli para cezası ile cezalandırılır.

YASAK CİHAZ VEYA PROGRAM KULLANIMI (HACKER ARAÇLARI)

TCK Madde 245/A:

Suçun Konusu: Sadece bilişim suçları işlemek amacıyla özel olarak hazırlanan veya oluşturulan yazılım, şifre, program veya cihazların imal edilmesi, ithal edilmesi, başkalarına verilmesi veya depolanması (örneğin exploit'ler, şifre kırma araçları).

Yaptırımı: Bu fiilleri işleyenler **bir yıldan üç yıla kadar hapis** ve adli para cezası ile cezalandırılır.

KIŞİSEL VERİLERİN KORUNMASI KANUNU

(KVKK – Kanun No: 6698)



KİŞİSEL VERİLERİN KORUNMASI KANUNU (KVKK)

Kişisel Verilerin Korunması Kanunu (KVKK - Kanun No: 6698)

Türkiye'de kişisel verilerin işlenmesinde başta özel hayatın gizliliği olmak üzere kişilerin temel hak ve özgürlüklerini korumak ve kişisel verileri işleyen gerçek ve tüzel kişilerin yükümlülüklerini belirlemek amacıyla **7 Nisan 2016** tarihinde yürürlüğe girmiştir.

Bilgi güvenliği ve etik perspektifinden bakıldığında KVKK, hem şirketler hem de kurumlar için teknik ve idari tedbirlerin alınmasını zorunlu kılan en temel yasal çerçevedir.

KVKK, TEMEL KAVRAMLAR

Kişisel Veri: Kimliği belirli veya belirlenebilir gerçek kişiye ilişkin her türlü bilgi (Örn: Ad, soyad, TCKN, e-posta adresi, telefon numarası, IP adresi).

Özel Nitelikli Kişisel Veri: Irk, etnik köken, siyasi düşünce, felsefi inanç, din, kılık kıyafet, dernek/vakıf üyeliği, sağlık, ceza mahkûmiyeti ve biyometrik/genetik veriler. (Bu verilerin izinsiz sızdırılması veya işlenmesi çok daha ağır cezai yaptırımlar doğurur).

Veri Sorumlusu: Kişisel verilerin işleme amaçlarını ve vasıtalarını belirleyen, veri kayıt sisteminin kurulmasından ve yönetilmesinden sorumlu olan gerçek veya tüzel kişi.

Veri İşleyen: Veri sorumlusunun verdiği yetkiye dayanarak onun adına kişisel verileri işleyen gerçek veya tüzel kişi (Örn: Bulut bilişim hizmeti aldığımız firma).

KİŞİSEL VERİLERİN İŞLENME ŞARTLARI

KVKK'ya göre kişisel veriler, genel olarak **ilgili kişinin açık rızası** olmaksızın işlenemez. Ancak kanun, istisnai olarak açık rıza aranmayan halleri de (örneğin kanunlarda açıkça öngörülmesi, bir sözleşmenin kurulması veya ifasıyla doğrudan ilgili olması, veri sorumlusunun hukuki yükümlülüğünü yerine getirebilmesi için zorunlu olması gibi) açıkça düzenlemiştir.

KİŞİSEL VERİLERİN İŞLENME ŞARTLARI

İşlenen verilerin şu ilkelere uygun olması şarttır:

1. Hukuka ve dürüstlük kurallarına uygun olma.
2. Doğru ve gerektiğinde güncel olma.
3. Belirli, açık ve meşru amaçlar için işlenme.
4. İşlendikleri amaçla bağlantılı, sınırlı ve ölçülü olma.
5. İlgili mevzuatta öngörülen veya işlendikleri amaç için gerekli olan süre kadar muhafaza edilme.

BİLGİ GÜVENLİĞİ AÇISINDAN ALINMASI GEREKEN TEDBİRLER (MADDE 12)

Veri sorumlusu, kişisel verilerin hukuka aykırı olarak işlenmesini önlemek, verilere hukuka aykırı olarak erişilmesini önlemek ve verilerin muhafazasını sağlamak amacıyla **uygun güvenlik düzeyini temin etmeye yönelik her türlü teknik ve idari tedbirleri almakla yükümlüdür.**

İdari Tedbirler: Çalışanlara yönelik kişisel veri güvenliği eğitimleri, gizlilik taahhütnameleri, kurum içi güvenlik politikalarının hazırlanması.

Teknik Tedbirler: Yetki matrisleri, sızma testleri, log kayıtlarının tutulması, güvenlik duvarları, güncel antivirüs sistemleri ve **kriptografik yöntemlerle şifreleme** (özellikle özel nitelikli veriler için).

CEZAI VE İDARI YAPTIRIMLAR

KVKK hükümlerine uyulmaması durumunda Kişisel Verileri Koruma Kurulu tarafından yüksek miktarda **idari para cezaları** kesilebilmektedir.

Ayrıca, verilerin hukuka aykırı olarak kaydedilmesi, yok edilmesi, ele geçirilmesi veya yayılması durumunda, daha önce bahsettiğimiz **Türk Ceza Kanunu'nun (TCK 135 - 140. maddeler)** ilgili hükümleri gereğince hapis cezaları da gündeme gelmektedir.

GÜVENLİK POLİTİKALARI VE STANDARTLAR

ISO 27001



GÜVENLİK POLİTİKASI NEDİR?

Güvenlik politikası, bir kurumun bilgi varlıklarını korumak için izleyeceği kuralları, prosedürleri, yetkileri ve sorumlulukları belirleyen üst düzey bir kılavuzdur.

Yönetimin Desteği: Bir güvenlik politikasının başarılı olması için kurum yönetiminin (üst yönetim) bunu sahiplenmesi ve desteklemesi şarttır. Sadece IT departmanının kurallarıyla sınırlı kalırsa başarısız olur.

Kapsam: Şirket içi şifreleme kurallarından internet kullanımına, masaüstü temizliği (clean desk policy) politikasından uzaktan çalışma (remote work) güvenlik kurallarına kadar geniş bir yelpazeyi kapsar.

ISO 27001 BILGI GÜVENLİĞİ YÖNETİM SİSTEMİ (BGYS)

43

Dünya çapında bilgi güvenliği denince akla gelen en temel uluslararası standart **ISO/IEC 27001**'dir.

BGYS (ISMS) Nedir?: Bilgi Güvenliği Yönetim Sistemi; bir kurumun hassas verilerini yönetmek ve korumak için seçtiği sistematik bir yaklaşımdır. Risk tabanlı bir mantıkla çalışır.

Sürekli İyileştirme (PDCA / PUKE Döngüsü): ISO 27001 standardı "bir kez kurduk bitti" mantığıyla çalışmaz. **Planla, Uygula, Kontrol Et, Önlem Al** (PDCA) döngüsüne dayanır. Güvenlik süreçleri sürekli izlenir, test edilir ve güncellenir.

Risk Yönetimi: Kurumdaki bilgi varlıklarının üzerindeki tehditler ve zafiyetler analiz edilir. Riskler kabul edilebilir seviyeye indirilir (riskten kaçınma, riski transfer etme, riski kabullenme veya riski azaltma).

ISO 27001 BILGI GÜVENLİĞİ YÖNETİM SİSTEMİ (BGYS)

ISO 27001 standardı ve bilgi güvenliği politikaları, bir kurumun sadece teknik açıklarını kapatmakla kalmaz; aynı zamanda yönetsel bir kültür oluşturur.

RISK YÖNETİMİ VE DEĞERLENDİRME SÜRECİ

45

ISO 27001'in kalbi **risk tabanlı düşünceye** dayanır. Kurumlar her şeyi aynı anda koruyamayacağı için kaynaklarını en kritik noktalara odaklamak zorundadır. Bu süreç dört temel adımdan oluşur:

- 1. Varlık Envanteri (Asset Identification):** Kurumdaki tüm bilgi varlıkları (veritabanları, sunucular, fiziksel evraklar, yazılımlar ve hatta çalışanların sahip olduğu yetkiler) listelenir ve sınıflandırılır.
- 2. Tehdit ve Zafiyet Analizi:** Varlıklara yönelik olası tehlikeler (tehditler) ve bu tehlikelerin istismar edebileceği açık noktalar (zafiyetler) belirlenir.
- 3. Risk Hesaplama:** Risk, *Olasılık x Etki* formülüyle değerlendirilir. Hangi riskin kurum için kabul edilebilir olduğu, hangisinin acil müdahale gerektirdiği matris üzerinden saptanır.
- 4. Risk İşleme (Risk Treatment):** Ortaya çıkan riskler için dört stratejiden biri seçilir:
 - i. Azaltma (Mitigation):** Teknik veya idari önlem alarak riski düşürmek (örn: güvenlik duvarı kurmak).
 - ii. Transfer Etme (Transfer):** Riski sigorta şirketi veya üçüncü taraf bir hizmet sağlayıcıya devretmek.
 - iii. Kaçınma (Avoidance):** Riski barındıran faaliyeti tamamen durdurmak.
 - iv. Kabul Etme (Acceptance):** Riskin maliyeti alım maliyetinden düşükse bilerek ve isteyerek kabul etmek.

RISK HESAPLAMA

Risk Eşik Değerleri Örneği:

1 - 3 Puan: Düşük Risk (İzlenebilir, acil müdahale gerekmez)

4 - 6 Puan: Orta/Yüksek Risk (Planlama yapılarak iyileştirilmeli)

9 Puan: Kritik Risk (Derhal aksiyon alınmalı, kabul edilemez)

Olasılık \ Etki	Düşük Etki (1)	Orta Etki (2)	Yüksek Etki (3)
Yüksek Olasılık (3)	Orta Risk (3)	Yüksek Risk (6)	Kritik Risk (9)
Orta Olasılık (2)	Düşük Risk (2)	Orta Risk (4)	Yüksek Risk (6)
Düşük Olasılık (1)	Düşük Risk (1)	Düşük Risk (2)	Orta Risk (3)

PRATİK BİR BILGI GÜVENLİĞİ SENARYOSU

Kurumunuzda yaptığınız risk analizinde şu senaryoyu ele aldığınızı düşünün:

Senaryo: "Şirket çalışanlarının e-posta hesaplarında iki aşamalı doğrulama (2FA) kullanılmıyor ve ortalama (phishing) saldırılarına karşı farkındalık eğitimleri yetersiz.»

Olasılık Değerlendirmesi (3 - Yüksek): Çalışanlar bilinçsiz olduğu ve koruma katmanı bulunmadığı için ortalama saldırısıyla hesapların ele geçirilme ihtimali çok yüksektir.

Etki Değerlendirmesi (3 - Yüksek): Bir saldırgan yetkili bir çalışanın e-postasını ele geçirdiğinde tüm kurumsal yazışmalara ve gizli verilere ulaşabilir (Yüksek zarar / İtibar kaybı).

Risk Puanı Hesaplaması: $3 \text{ (Olasılık)} \times 3 \text{ (Etki)} = 9 \text{ (Kritik Risk)}$

Bu matris bize bu riskin en üst önceliğe sahip olduğunu ve derhal **azaltma (mitigation)** stratejisi uygulanarak tüm şirkette 2FA zorunluluğu getirilmesi gerektiğini net bir şekilde gösterir.

SÜREKLİ İYİLEŞTİRME: PDCA (PUKE) DÖNGÜSÜ

ISO 27001 statik bir belge değildir; yaşayan bir süreçtir. Bu süreç **Planla, Uygula, Kontrol Et, Önlem Al** döngüsüyle yönetilir:

Planla (Plan): BGYS kapsamı belirlenir, risk değerlendirmesi yapılır ve risk işleme planı hazırlanır.

Uygula (Do): Güvenlik politikaları, prosedürler ve belirlenen teknik/idari kontroller hayata geçirilir, çalışanlara eğitimler verilir.

Kontrol Et (Check): Sistem düzenli olarak denetlenir, iç tetkikler (internal audit) yapılır, loglar incelenir ve zafiyet taramaları gerçekleştirilir.

Önlem Al (Act): Denetim sonuçlarında tespit edilen uygunsuzluklar giderilir ve sistem bir sonraki seviye için güncellenir.

Plan, do, check, act

Identify the issue

Define the problem, gather relevant data, and formulate a hypothesis. What exactly are you trying to achieve? What resources do you need?

Plan

Quickly try out a solution

Implement your plan – but start small. This stage is a controlled experiment, not full-scale deployment.

Do

See if it works

Step back and examine what happened. Did you get the desired result? Why or why not? Compare your actual outcomes against your predictions, looking for insights and unexpected consequences.

Check

Launch or adjust

If your solution proved effective, how can you implement it more widely? If it fell short, what adjustments are needed? Perhaps you need to return to the planning stage with new insights.

Act

BiteSize Learning

ISO 27001:2022 İLE GELEN KONTROL GRUPLARI (ANNEX A)

Standardın güncel versiyonunda güvenlik kontrolleri (önceden 114 iken) sadeleştirilerek **93 kontrole** düşürülmüş ve 4 ana başlık altında toplanmıştır:

Örgütsel Kontroller (Organizational Controls): Tehdit istihbaratı, bilgi güvenliği politikaları, varlık yönetimi, uzaktan çalışma kuralları ve tedarikçi ilişkileri.

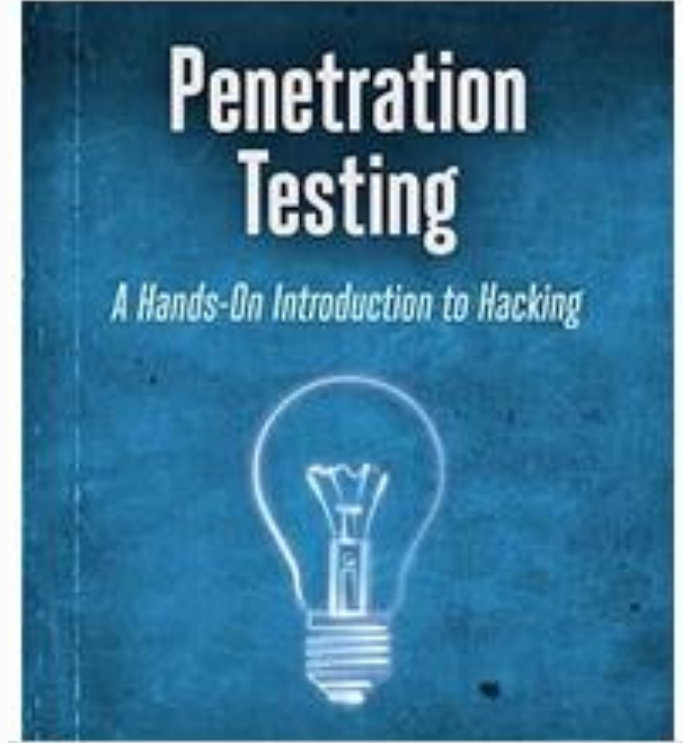
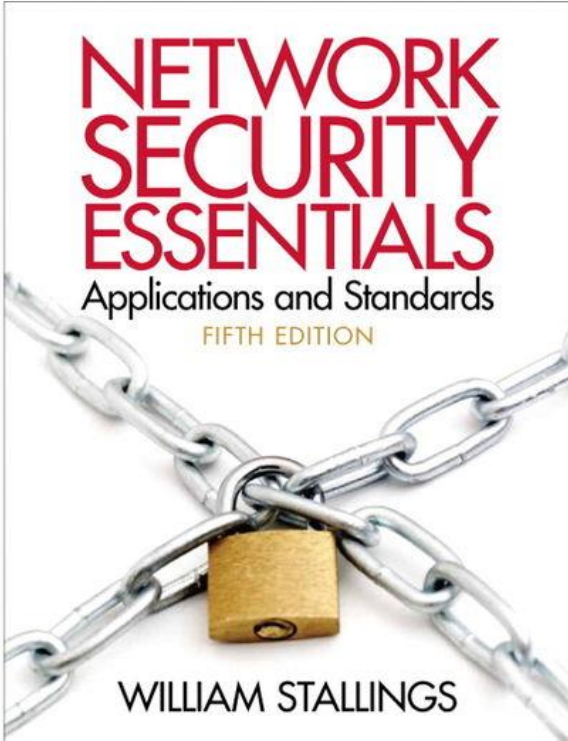
Kişisel Kontroller (People Controls): İşe alım öncesi taramalar, farkındalık eğitimleri, disiplin süreçleri ve sözleşmeler.

Fiziksel Kontroller (Physical Controls): Periyodik güvenlik alanları, fiziksel erişim kontrolleri, ekipman güvenliği ve temiz masa/ekran politikaları.

Teknolojik Kontroller (Technological Controls): Kullanıcı erişim hakları, şifreleme, kötü amaçlı yazılımlara karşı koruma, ağ güvenliği, loglama ve zafiyet yönetimi.

DERS İÇİN KAYNAKLAR

50



OKUMA KAYNAKLARI

Aristoteles – Nikomakhos'a Etik (Çev. Saffet Babür / İş Bankası Kültür Yayınları)

Platon – Devlet (Çev. Sabahattin Eyüboğlu – M. Ali Cimcoz / İş Bankası Kültür Yayınları)

Platon – Sokrates'in Savunması, Kriton, Gorgias (İş Bankası Kültür Yayınları / Doğu Batı Yayınları)

Marcus Aurelius – Düşünceler (Çev. Şahin Alp / İş Bankası Kültür Yayınları)

Pierre Hadot – Ruhsal Egzersizler ve Antik Felsefe (Çev. Lale Arslan Özcan / Dost Kitabevi)

William Stallings – Ağ Güvenliği Essentials (Network Security Essentials) (Türkçe çevirisi mevcut – Nobel Akademik Yayıncılık)



THANKS!

Any questions?

You can find me at:
yilmazagca@Trabzon.edu.tr

